

Anomali Senaryosu Raporu

Senaryo Adı: CSMS Yetki Ele Geçirme Yoluyla Ekran Manipülasyonu (Defacement)
Referans Olaylar: Rosseti/AutoEnterprise Vakası (Rusya, 2022), Isle of Wight Vakası (İngiltere, 2022)

Hazırlayan: Kardelen Demir

1. Amaç

Saldırganın temel amacı, Merkezi Yönetim Sistemi'nin (CSMS) yönetsel ayrıcalıklarını (örn. operatör veya admin hesabı) ele geçirmektir. Bu ayrıcalıklar kullanılarak, meşru bir OCPP komutu olan `SetDisplayMessage.req` (veya üreticiye özel benzer bir komut) istasyon ağına "toplu yayın" (broadcast) ile gönderilir. Nihai hedef, istasyon ekranlarına yanıltıcı, politik veya itibar zedeleyici metinler basarak şirketin marka güvenilirliğini sarsmak, kullanıcıları manipüle etmek ve kamuoyunda panik yaratmaktır.

2. Tehdit Kategorisi (STRIDE)

- Kurcalama (Tampering):** Şarj istasyonunun ekranında gösterilen yasal ve operasyonel verilerin (fiyat, talimat) yetkisiz ve sahte verilerle değiştirilmesi.
- Bilgi İfşası (Information Disclosure):** (Dolaylı) Gerçek fiyatlandırma veya güvenlik uyarılarının yerine sahte bilgilerin basılması.
- Hizmet Reddi (Denial of Service):** Meşru bilgilerin (örn. "Arıza Kodu: 5") görüntülenmesinin engellenmesi, istasyonun operasyonel olarak kullanılamaz hale gelmesi (kullanıcı güveni açısından).
- Ayrıcalık Yükseltme (Elevation of Privilege):** Düşük seviyeli bir operatör hesabının (eğer zafiyet varsa) veya dışarıdan elde edilen bir erişimin, tüm istasyon ağına komut gönderebilecek (broadcast) bir ayrıcalığa dönüştürülmesi.

3. Ön Koşullar

- Zayıf CSMS Güvenliği:** Saldırganın CSMS yönetim paneline (Web Arayüzü veya API) erişim sağlamış olması. Bu erişim şu yollarla elde edilebilir:
 - Varsayılan/Zayıf Parolalar:** Yönetici veya operatör hesapları için (`admin/12345`).
 - Kimlik Bilgisi Hırsızlığı:** CSMS operatörlerine yönelik Oltalama (Phishing) saldırısı.
 - Güvensiz API:** Mobil uygulama veya entegrasyon API'lerindeki bozuk erişim kontrolü (Broken Access Control) zafiyetleri.
- Tedarikçi Arka Kapısı:** (Rusya vakasında olduğu gibi) CSMS yazılımını veya CP donanımını sağlayan üçüncü parti bir tedarikçinin, bakım amacıyla bıraktığı uzaktan erişim "arka kapısının" (backdoor) saldırgan tarafından sömürülmesi.
- MFA Eksikliği:** Kritik CSMS yönetim panellerinde Çok Faktörlü Kimlik Doğrulama (MFA) kullanılmaması, parola hırsızlığını tek başına yeterli hale getirir.

4. Saldırı Vektörü ve Adım Adım Yürütme

Saldırı, CSMS'in ele geçirilmesi ve komutun kötüye kullanılmasını içerir.

1. **Aşama 1: CSMS Sızması (Yetki Elde Etme)**
 - Saldırgan, bir ortalama e-postası ile bir CSMS operatörünün oturum çerezini (session cookie) veya parolasını çalar.
 - Operatör hesabını kullanarak CSMS yönetim paneline giriş yapar. MFA olmadığı için bu tek adım yeterlidir.
2. **Aşama 2: Kötüye Kullanım (İşlevin Silahlandırılması)**
 - Saldırgan, yönetim panelinde "İstasyon Yönetimi", "Toplu İşlemler" veya "Grup Ayarları" gibi bir menü arar.
 - "Ekran Mesajı Gönder" veya "Duyuru Yap" benzeri bir işlev bulur. Bu işlev, arka planda `SetDisplayMessage.req` komutunu tetikler.
 - Mesaj içeriği olarak "FİYATLAR 0 TL!" veya "UKRAYNA'YA DESTEK VERİN!" gibi itibar zedeleyici/yanıltıcı bir metin girer.
 - Hedef olarak tek bir istasyon yerine "Tüm İstasyonlar" (veya belirli bir bölgedeki tüm istasyonlar) seçeneğini seçer.
3. **Aşama 3: Yürütme (Komut Gönderimi)**
 - CSMS, bu komutu *yetkili bir operatörden gelmiş meşru bir talep* olarak algılar.
 - Bu talebi, yönetim altındaki binlerce istasyona `[2, "msg-id", "SetDisplayMessage", {"message": ...}]` formatında bir OCPP komutu olarak iletir.
4. **Aşama 4: Etki (Defacement)**
 - Ağdaki tüm istasyonlar (CP) bu komutu alır, `SetDisplayMessage.conf` (`Accepted`) yanıtını döner ve ekranlarındaki mevcut metni *anında* saldırıncının metniyle günceller.
 - Saldırı, dakikalar içinde yüzlerce istasyonda görünür hale gelir.

5. Beklenen Fiziksel/Anormal Sonuç

- **Görsel Kanıt:** Şirketin logosunu taşıyan istasyonlarda, politik sloganlar, hakaretler, sahte fiyat bilgileri (0 TL) veya pornografik/rahatsız edici içeriklerin (İngiltere vakası) görüntülenmesi.
- **İtibar Kaybı:** Kullanıcıların bu ekranların fotoğraflarını çekip sosyal medyada paylaşmasıyla ("X Markası Hacklendi") şirketin itibarının hızla zedelenmesi.
- **Kullanıcı Paniği:** "Kredi Kartı Bilgileriniz Çalındı!" gibi sahte bir mesaj, kullanıcılar arasında kitlesel paniğe yol açabilir.
- **Operasyonel Kaos:** "Şarj Bedava" mesajı, istasyonlarda aşırı yoğunluğa ve gelir kaybına neden olabilir.

6. Adli Bilişim İzleri (Forensic Artifacts) ve Tespit

- **CSMS Uygulama Logları (En Kritik İz):**
 - `SetDisplayMessage` komutunu tetikleyen operatör hesabının (audit trail) kaydı.
 - Bu komutu tetikleyen hesabın giriş yaptığı IP adresi (GeolP konumu), giriş saati (örn. gece 03:00) veya ASN bilgisi (normal operatör trafiğinden farklı bir veri merkezi IP'si).
- **CSMS OCPP Trafik Logları:**
 - Ağ genelinde `SetDisplayMessage.req` komutunun *frekansında* ani bir patlama (Spike). (Normalde bu komut ayda bir kez veya çok nadir kullanılır).
 - Bu komutun tekil değil, "broadcast" (binlerce istasyona aynı anda) olarak gönderilmiş olması.
- **Anomali Tespiti (ADS için Kural):**
 - **KURAL-01 (Yüksek Öncelikli):** EĞER `SetDisplayMessage` VEYA `UpdateFirmware` VEYA `SetConfiguration` komutları, "Tüm İstasyonlar" (broadcast) kapsamıyla kullanılırsa → KRİTİK ALARM ÜRET.

- **KURAL-02 (Orta Öncelikli):** EĞER `SetDisplayMessage` komutunu tetikleyen operatörün IP'si, daha önce görülmemiş (unseen) bir IP/GeoIP ise VEYA normal çalışma saatleri dışındaysa → YÜKSEK ÖNCELİKLİ ALARM ÜRET.
- **KURAL-03 (Düşük Öncelikli):** `SetDisplayMessage` komutunun *içeriği* (*payload*), beklenen "yasal metin/tarife" formatının dışında anahtar kelimeler (politika, hakaret vb.) içeriyorsa (DPI gerektirir) → BİLGİLENDİRME ALARMI ÜRET.